

GUIA COMPLETO OSINT — Open Source Intelligence

Metodologia, Técnicas e Plano de Estudos
para Investigação de Alta Qualidade

Aviso Legal

Este guia destina-se exclusivamente a fins educacionais e a testes em perfis criados por você mesmo. A coleta de informações sobre terceiros sem autorização pode violar leis de privacidade (LGPD, GDPR) e constituir crime de invasão de privacidade. Sempre respeite os limites éticos e legais.

Julho de 2026

SUMÁRIO

- 1. O que é OSINT e por que é essencial
- 2. O Framework de Inteligência: O Ciclo de OSINT
- 3. Por Onde Começar? — O Plano de 4 Semanas
- 4. Fase 1: Reconhecimento Passivo (Sem Toque no Alvo)
- 5. Fase 2: Reconhecimento Ativo (Interação Indireta)
- 6. Fase 3: Análise e Correlação de Dados
- 7. Fase 4: Relatório e Documentação
- 8. Técnicas Avançadas de Alta Qualidade
- 9. Ferramentas por Categoria
- 10. Exercício Prático: Investigar seu Próprio Perfil
- 11. Erros Comuns de Iniciantes
- 12. Métricas de Progresso e Autoavaliação
- 13. Recursos e Comunidades

1. O que é OSINT e por que é essencial

OSINT (Open Source Intelligence) é a coleta, análise e interpretação de informações disponíveis publicamente para produzir inteligência acionável. No contexto de cibersegurança, OSINT é usado para:

- Mapear a superfície de ataque de uma organização antes do pentest
- Identificar vetores de engenharia social (phishing, spear-phishing)
- Descobrir credenciais vazadas, dados expostos e configurações erradas
- Rastrear atividades de ameaças (threat intelligence)
- Verificar a pegada digital de uma pessoa ou empresa

OSINT é LEGAL quando:

- As informações são PUBLICAMENTE acessíveis (sites, redes sociais, registros públicos)
- Não há violação de termos de serviço (scraping massivo pode ser proibido)
- Não há invasão de sistemas privados (bancos de dados hackeados = ilegal)
- O propósito é defesa, pesquisa ou educação

OSINT é ILEGAL quando:

- Acessa bancos de dados hackeados (haveibeenpwned é OK; vender dados = crime)
- Realiza engenharia social ativa sem autorização (ligar, enviar e-mails falsos)
- Stalking ou perseguição de indivíduos
- Violação de privacidade conforme LGPD/GDPR

2. O Framework de Inteligência: O Ciclo de OSINT

O OSINT não é 'googlear aleatoriamente'. É um processo estruturado com 5 fases:

Fase	O que faz	Saída esperada
1. Planejamento e Direcionamento	Define o que buscar, por que buscar e limites éticos/legais	Lista de requisitos de inteligência (IRs)
2. Coleta	Busca ativa e passiva de dados em fontes abertas	Dados brutos: textos, imagens, metadados, registros
3. Processamento	Organiza, limpa e prepara os dados para análise	Dados estruturados: tabelas, timelines, grafos
4. Análise	Conecta pontos, identifica padrões e gera hipóteses	Inteligência: conclusões com evidence
5. Disseminação	Documenta e entrega resultados ao stakeholder	Relatório acionável com recomendações

A chave do OSINT de qualidade

A diferença entre um iniciante e um profissional de OSINT não está na quantidade de ferramentas, mas na QUALIDADE do raciocínio analítico. Um profissional conecta 3 fontes fracas para criar 1 conclusão forte. Um iniciante coleta 100 fontes e não conecta nenhuma.

3. Por Onde Começar? — O Plano de 4 Semanas

Este plano foi desenhado para quem criou perfis de treino (e-mails, contas, informações fictícias) e quer aprender OSINT de forma estruturada. Cada semana tem objetivos claros e exercícios práticos.

Semana 1: Fundamentos	Atividades
Objetivo	Entender o que é OSINT, diferenciar passivo de ativo, conhecer as fontes principais
Teoria	Ler sobre o ciclo de inteligência; estudar termos: DNI, PAI, SOCMINT, GEOMINT, IMINT
Prática	Criar conta no Google com alias separado para OSINT; configurar ambiente isolado (VM ou container)
Exercício	Pesquisar seu próprio nome real no Google (modo anônimo); anotar TUDO que aparece

Semana 2: Técnicas de Busca	Atividades
Objetivo	Dominar operadores de busca, engenharia reversa de imagens, mapeamento de redes sociais
Teoria	Google Dorks (site:, filetype:, intitle:, inurl:, cache:); operadores booleanos (AND, OR, NOT)
Prática	Usar Google Dorks para encontrar informações sobre seu perfil de treino; usar TinEye/Google Images para reverse image search
Exercício	Investigar UM perfil de treino completo: e-mail → redes sociais → posts → conexões → localizações

Semana 3: Ferramentas e Automação	Atividades
Objetivo	Automatizar coleta com ferramentas; entender APIs; usar OSINT frameworks
Teoria	Como funcionam APIs de redes sociais; limites de rate; etiqueta de scraping
Prática	Instalar e usar: theHarvester, Maltego (CE), Spiderfoot, Sherlock, Holehe; usar HaveIBeenPwned para e-mails

Exercício	Mapear TODAS as contas de um perfil de treino usando Sherlock + Holehe; criar grafo no Maltego
------------------	--

Semana 4: Análise e Relatório	Atividades
Objetivo	Correlacionar dados, identificar padrões, produzir relatório profissional de OSINT
Teoria	Análise de associação; timelines; análise de redes (social network analysis); identificação de bias
Prática	Criar timeline de atividades; montar árvore genealógica de contas; identificar padrões de comportamento
Exercício	Produzir relatório completo de um perfil de treino com: executive summary, metodologia, findings, timeline, conclusões, recomendações

4. Fase 1: Reconhecimento Passivo (Sem Toque no Alvo)

Reconhecimento passivo significa coletar informações SEM interagir diretamente com o alvo. O alvo NÃO SABE que está sendo investigado. É o método mais seguro e ético.

4.1 Técnicas de busca avançada (Google Dorks):

Operador	Função	Exemplo Prático
site :	Restringe a um domínio	site:linkedin.com "João Silva" "São Paulo"
filetype :	Busca por tipo de arquivo	filetype:pdf "relatório interno" site:empresa.com.br
intitle :	Busca no título da página	intitle:"index of" "config.json"
inurl :	Busca na URL	inurl:admin.php site:alvo.com.br
cache :	Versão em cache do Google	cache:alvo.com.br (página removida)
" "	Busca exata da frase	"e-mail: joao.silva@ alvo.com"
-	Exclui termo	joao.silva -facebook -linkedin (remove redes)
*	Coringa (wildcard)	joao.*.silva@gmail.com (encontra variações)

4.2 Fontes de dados passivas:

Categoria	Fonte	O que revela
Redes Sociais	LinkedIn, Twitter/X, Instagram, Facebook, TikTok, Reddit	Emprego, conexões, interesses, localização, hábitos, timeline
Registros Públicos	Receita Federal, Junta Comercial, Tribunais	CNPJ, sócios, processos, bens, endereços
Vazamentos	HackTheBox, DeHashed, IntelX	E-mails, senhas, hashes, dados pessoais
Tecnologia	Shodan, Censys, Fofa, BinaryEdge	IPs, portas abertas, serviços, banners, vulnerabilidades
DNS e WHOIS	WHOIS, DNSDumpster, SecurityTrails	Registrante, servidores DNS, subdomínios, histórico de IP
Arquivos	Wayback Machine, Google Cache, DocumentCloud	Versões antigas de sites, documentos removidos, PDFs

5. Fase 2: Reconhecimento Ativo (Interação Indireta)

Reconhecimento ativo envolve interação INDIRETA com o alvo — você toca nos sistemas do alvo, mas de forma que não seja identificável como investigação. O alvo pode registrar a interação, mas não sabe o propósito.

5.1 Técnicas ativas permitidas:

Técnica	Como funciona	Risco de detecção
Ping / Traceroute	Envia pacotes ICMP para mapear rota até o alvo	Baixo — tráfego normal de rede
Port Scan (nmap)	Envia pacotes TCP/UDP para descobrir portas	Médio — pode ser detectado por IDS/IPS
Banner Grabbing	Conecta em serviço e captura versão/banner	Baixo — parece conexão legítima
DNS Enumeration	Consulta registros DNS (NS, MX, TXT, A)	Baixo — tráfego DNS é normal
Subdomain Bruteforce	Testa milhares de subdomínios possíveis	Médio — volume alto pode alertar

5.2 Comandos práticos:

- # DNS Enumeration
- dig +short NS alvo.com.br
- dig +short MX alvo.com.br
- dig +short TXT alvo.com.br
- dnsrecon -d alvo.com.br -t std,brt -D /usr/share/wordlists/subdomains.txt
-
- # Subdomain discovery
- sublist3r -d alvo.com.br -o subdomains.txt
- amass enum -d alvo.com.br -o amass.txt
-
- # Port scan discreto (evitar detecção)
- nmap -sS -T2 -p- --top-ports 1000 alvo.com.br
- nmap -sV --version-intensity 3 -p 80,443,8080 alvo.com.br
-
- # Banner grabbing
- nc -v alvo.com.br 80
- curl -I http://alvo.com.br

6. Fase 3: Análise e Correlação de Dados

Coletar dados é fácil. A habilidade que separa iniciantes de profissionais é a CAPACIDADE DE CONECTAR PONTOS. Esta fase transforma dados brutos em inteligência.

6.1 Técnicas de análise:

- Timeline Analysis: Organizar eventos cronologicamente para identificar padrões de comportamento
- Social Network Analysis (SNA): Mapear conexões entre pessoas, empresas e contas
- Geolocation Correlation: Cruzar fotos, posts e metadados para rastrear localizações
- Pattern Recognition: Identificar padrões em nomes de usuário, e-mails, senhas
- Gap Analysis: Identificar o que está FALTANDO nas informações coletadas

6.2 Exemplo de correlação real:

Suponha que você encontrou um e-mail de treino: 'joao.silva.treino@gmail.com'. Veja como conectar os pontos:

- Passo 1: Verificar vazamentos
 - haveibeenpwned.com → e-mail vazado em 3 breaches
 - DeHashed → senha antiga encontrada: 'Joao2020!'
- Passo 2: Buscar username em redes sociais
 - Sherlock: joao.silva.treino encontrado em Twitter, Instagram, GitHub
 - Twitter: posts geotagged em São Paulo, SP
 - Instagram: fotos com metadados GPS (25.4294, -49.2719)
- Passo 3: Analisar conexões
 - LinkedIn: trabalha na Empresa X desde 2022
 - GitHub: repositórios com código da Empresa X (leak de IP interno)
 - Colaboradores no GitHub: 2 contas com mesmo padrão de e-mail
- Passo 4: Timeline
 - 2020: Conta criada (senha fraca)
 - 2021: Primeiro vazamento (senha reutilizada)
 - 2022: Mudou de emprego (LinkedIn)
 - 2023: Postou foto com badge da Empresa X (revelou andar/departamento)
 - 2024: Commit no GitHub com IP interno 10.0.5.x
- CONCLUSÃO: Perfil mapeado com superfície de ataque identificada:

- → Vetor 1: Phishing com tema da Empresa X (alta credibilidade)
- → Vetor 2: Credential stuffing com senha vazada 'Joao2020!'
- → Vetor 3: Engenharia social baseada em hobbies (fotos de corrida)

O poder da correlação

Cada dado isolado é fraco. O e-mail sozinho não diz nada. A senha sozinha não diz nada. A foto sozinha não diz nada. MAS: e-mail + senha vazada + foto geotagged + repositório GitHub = perfil completo com múltiplos vetores de ataque. É a SOMA que cria valor.

7. Fase 4: Relatório e Documentação

Um relatório de OSINT de alta qualidade não é uma lista de links. É um documento estruturado que conta uma história com evidências, conclusões e recomendações.

7.1 Estrutura do relatório:

Seção	Conteúdo	Dica
Executive Summary	Resumo de 1 página para decisores	Foque em riscos e impactos, não em técnicas
Scope e Limitações	O que foi investigado e o que NÃO foi	Define limites étnicos e legais
Methodology	Fontes, ferramentas e técnicas usadas	Permite reprodutibilidade
Findings	Descobertas organizadas por categoria	Use evidências: screenshots, URLs, metadados
Timeline	Eventos em ordem cronológica	Visualize padrões de comportamento
Conclusions e Recommendations	O que os dados provam e como mitigar riscos	Seja acionável: quem faz o quê até quando

7.2 Regras de documentação:

- Sempre capture screenshot com timestamp e URL visível
- Salve metadados de imagens (EXIF) antes de processá-las
- Use hashes SHA-256 para provar integridade de arquivos coletados
- Mantenha chain of custody: quem coletou, quando, de onde
- Separe FACTS (dados comprovados) de ASSESSMENTS (sua interpretação)

8. Técnicas Avançadas de Alta Qualidade

8.1 Geolocation e Geointelligence (GEOINT):

- Reverse Image Search: Encontrar onde uma foto já apareceu na internet
- EXIF Analysis: Extrair GPS, modelo de câmera, data/hora de fotos
- Shadow Analysis: Calcular hora do dia pela posição das sombras na foto
- Landmark Identification: Identificar prédios, placas, vegetação para localizar
- Google Earth Pro: Comparar fotos com imagens de satélite históricas

- # Extrair EXIF de imagem
- `exiftool foto.jpg`
- `exiftool -gpslatitude -gpslongitude foto.jpg`
-
- # Busca reversa de imagem
- # Google Images: `images.google.com` → ícone de câmera
- # TinEye: `tineye.com`
- # Yandex Images: `yandex.com/images` (melhor para rostos)

8.2 Username Enumeration e Pattern Analysis:

- Identificar padrões de nomenclatura: `joao.silva`, `joaosilva`, `joao_silva_2020`
- Gerar variações de username com combinações de nome + ano + número
- Usar Namechk ou KnowEm para verificar disponibilidade em 500+ sites
- Analisar 'username history' em plataformas que permitem mudança (Twitter, GitHub)

- # Sherlock – busca username em 300+ redes sociais
- `sherlock joao.silva.treino`
- `sherlock joao.silva --site twitter instagram github linkedin`
-
- # Holehe – verifica e-mail em 100+ serviços sem enviar notificação
- `holehe joao.silva.treino@gmail.com`

8.3 E-mail OSINT e Vazamentos:

- HaveIBeenPwned: Verificar se e-mail apareceu em vazamentos conhecidos
- DeHashed / IntelX: Buscar dados vazados por e-mail, requer API key
- Hunter.io: Descobrir padrão de e-mails corporativos (ex: `{first}.{last}@empresa.com`)

- Email-Rep.io: Verificar reputação e associações de um e-mail
- # theHarvester – coleta e-mails, subdomínios, hosts, employee names
- theHarvester -d alvo.com.br -b all -f resultado.html
- theHarvester -d alvo.com.br -b google,linkedin,bing -l 500

8.4 Dark Web e Deep Web:

- Ahmia.fi: Motor de busca para sites .onion (Tor)
- OnionSearch: Ferramenta CLI para buscar na dark web
- IMPORTANTE: Acessar dark web requer Tor Browser e precauções de OPSEC

9. Ferramentas por Categoria

Categoria	Ferramenta	Função Principal
Busca	Google Dorks / Hacking	Operadores avançados de busca
Busca	Shodan	Busca de dispositivos conectados à internet
Busca	Censys	Análise de infraestrutura e certificados
Redes Sociais	Sherlock	Busca username em 300+ plataformas
Redes Sociais	Holehe	Verifica e-mail em 100+ serviços
Redes Sociais	Maltego CE	Visualização de relacionamentos (grafo)
E-mail	theHarvester	Coleta e-mails, hosts, employee names
E-mail	Hunter.io	Descobre padrões de e-mails corporativos
E-mail	HavelBeenPwned	Verifica vazamentos de e-mails
E-mail	DeHashed / IntelX	Busca em bancos de dados vazados
DNS / Web	DNSRecon	Enumeração de DNS e subdomínios
DNS / Web	Sublist3r	Descoberta de subdomínios
DNS / Web	Amass	Mapeamento de infraestrutura web
DNS / Web	Wayback Machine	Arquivos históricos de websites
Análise	ExifTool	Extração de metadados de imagens

10. Exercício Prático: Investigar seu Próprio Perfil

Este exercício foi desenhado para quem criou perfis de treino. O objetivo é mapear 100% da pegada digital de um perfil fictício que VOCÊ criou.

10.1 Preparação:

- Crie um perfil completo fictício: nome, e-mail, data de nascimento, cidade, emprego, hobbies
- Crie contas em: Gmail, Twitter, LinkedIn, Instagram, GitHub, Reddit (use VPN/VM)
- Poste conteúdo realista: fotos (com metadados), posts, conexões, repositórios
- Aguarde 48-72h para indexação pelo Google

10.2 Checklist de investigação:

- ☐ PASSO 1: Buscar e-mail no Google (modo anônimo)
 - → `site:haveibeenpwned.com 'e-mail@treino.com'`
 - → `holehe e-mail@treino.com`
 -
- ☐ PASSO 2: Buscar username em redes sociais
 - → `sherlock username.treino`
 - → `namechk.com`
 -
- ☐ PASSO 3: Analisar fotos postadas
 - → Baixar imagens e extrair EXIF
 - → `exiftool foto_perfil.jpg`
 - → Reverse image search no Google/Yandex
 -
- ☐ PASSO 4: Mapear conexões
 - → LinkedIn: quem segue, quem é seguido, empresas
 - → GitHub: colaboradores, repositórios, commits
 - → Twitter: interações, hashtags, localizações
 -
- ☐ PASSO 5: Buscar padrões
 - → Variações de username: `joao.silva`, `joaosilva`, `joao_silva`
 - → Senhas reutilizadas em vazamentos
 - → Padrão de horários de postagem (fuso horário?)
 -
- ☐ PASSO 6: Montar grafo de relacionamentos
 - → Maltego: importar contas e conexões
 - → Identificar 'pontos de convergência' (amigos em comum)

-
- □ PASSO 7: Produzir relatório
- → Executive summary: 'Perfil X expõe Y riscos'
- → Timeline de atividades
- → Vetores de ataque identificados
- → Recomendações de mitigação

Métrica de sucesso

Você domina OSINT quando consegue mapear um perfil fictício que VOCÊ criou melhor do que o próprio criador se lembra. Se você descobre dados que ESQUECEU de ter postado, está no caminho certo.

11. Erros Comuns de Iniciantes

Erro	Por que é ruim	Como corrigir
Usar conta pessoal para OSINT	Expõe sua identidade real e contamina os resultados	Crie conta separada com alias; use VM dedicada
Não documentar fontes	Perde credibilidade; não consegue reproduzir	Screenshot com URL e timestamp; salve metadados
Confundir FACT com ASSESSMENT	Relatório fraco com conclusões não sustentadas	Separe: Dado X prova Y de Parece que Z
Focar em quantidade de dados	Coleção desorganizada sem análise	Menos é mais: conecte 3 fontes fortes
Ignorar limites étnicos/legais	Pode cometer crimes de privacidade	Defina scope antes; consulte LGPD/GDPR
Não verificar veracidade	Informação falsa contamina análise	Cruze fontes; descarte dados não confirmáveis

12. Métricas de Progresso e Autoavaliação

Use esta tabela para avaliar seu nível a cada 2 semanas. Seja honesto — a autoavaliação é a ferramenta mais poderosa de aprendizado.

Habilidade	Iniciante	Intermediário	Avançado
Google Dorks	Usa site: e filetype:	Combina 3+ operadores por busca	Cria dorks customizados para casos específicos
Redes Sociais	Busca manual em 1-2 plataformas	Usa Sherlock/Holehe para 50+ plataformas	Mapeia conexões e padrões de comportamento
Geolocation	Olha GPS no smartphone	Extraí EXIF e usa Google Earth	Identifica local por landmarks e sombras
Correlação	Lista dados isolados	Conecta 2 fontes	Conecta 4+ fontes fracas em 1 conclusão forte
Ferramentas	Usa 2-3 ferramentas	Domina 8-10 ferramentas	Cria pipelines de automação com APIs
Relatório	Lista links e prints	Estrutura com executive summary	Relatório acionável com recomendações priorizadas
OPSEC	Usa conta pessoal	Usa VM + alias	VM isolada + VPN + conta dedicada + procedimentos de limpeza
Ética/Legal	Não conhece limites	Define scope antes	Consulta jurídico para casos complexos

13. Recursos e Comunidades

13.1 Sites e Bancos de Dados:

- osintframework.com — Framework completo de ferramentas OSINT
- osintcurious.io — Blog com tutoriais e casos reais
- sector035.nl — Artigos avançados de OSINT e geolocation
- haveibeenpwned.com — Verificação de vazamentos
- shodan.io — Busca de dispositivos conectados
- intelx.io — Motor de busca de dados vazados
- waybackmachine.org — Arquivos históricos da web

13.2 Comunidades:

- [r/OSINT](https://www.reddit.com/r/OSINT) — Comunidade Reddit com cases e discussões
- OSINT Curious Discord — Comunidade ativa de aprendizado
- Trace Labs — Organização que usa OSINT para casos reais de pessoas desaparecidas
- Bellingcat — Jornalismo de investigação com OSINT (nível avançado)

13.3 Cursos recomendados:

- OSINT Curious: Introduction to OSINT (gratuito)
- SANS SEC487: Open-Source Intelligence (pago, nível profissional)
- Udemy: The Complete OSINT Training (intermediário)
- YouTube: Sector035, OSINT Curious, Bellingcat (gratuito)

Lembrete Final

OSINT é uma habilidade que se desenvolve com PRÁTICA, não com leitura. Crie seus perfis de treino, investigue-os, documente os resultados, compare com o que esperava encontrar, e repita. A qualidade vem da repetição consciente e da análise crítica dos próprios erros.